27.08.2024

Romsis Yazılım ve Bilgi Teknolojileri

Inflight Mobil Uygulama Sızma Testi Raporu v1.0

Sızma Testi Tarihi:

16.08.2024 – 22.08.2024

RSU
Bilişim ve Danışmanlık

GİZLİ

İçindekiler

YÖNETİCİ ÖZETİ 2
Test Kapsamı 6
Uyarı 7
Sızma Testi Metodolojisi 8
Mobil Uygulama Sızma Testi Kontrol Listesi 9
Kullanılan Araçlar 9
MOBİL UYGULAMA SIZMA TESTİ BULGULARI 10
1. Acil Seviye Mobil Uygulama Sızma Testi Bulguları 10
2. Kritik Seviye Mobil Uygulama Sızma Testi Bulguları 10
3. Yüksek Seviye Mobil Uygulama Sızma Testi Bulguları 10
4. Orta Seviye Mobil Uygulama Sızma Testi Bulguları 11
4.1. İnternetten Erişilebilir Hassas Servisler 11
4.2. Erişim Kontrolünün Olmaması 13
4.3. Güncel Olmayan JavaScript Kütüphanesi Kullanımı 15
5. Düşük Seviye Mobil Uygulama Sızma Testi Bulguları 17
5.1. Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması 17
5.2. Hassas Bilgilerin Erişilebilir Olması 19
5.3. HTTP Başlık Bilgisi Eksiklikleri 20
5.4. Basic Authentication Kullanımı 22
5.5. Uygulamada Güvensiz Veri Depolanması 23

YÖNETİCİ ÖZETİ

Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti.'nin (Kurum) risklerinin belirlenebilmesi için, Inflight mobil uygulamasına Anonim ve standart kullanıcı yetkileri ile sızma testleri gerçekleştirilmiştir. Bu testler sonucunda Kurum bilgi varlıklarının güvenliğini etkileyen Acil seviyede bulgu tespit edilmemiştir.

Genel olarak bulgular dikkate alındığında, Kurumun aşağıdaki konularda gelişmeye açık yönleri olduğu değerlendirilmektedir:

- Uygulama Sıkılaştırmaları
- OS/Servis Sıkılaştırmaları
- Erişim Kısıtlamaları
- Yama Yönetimi

Çalışma sonucunda, 3 Orta ve 5 Düşük seviye olmak üzere toplam 8 bulgu tespit edilmiştir. Bulgu dağılımı incelendiğinde, Kurumun güvenlik ürünlerini efektif kullandığı, Kritik zafiyet oluşturabilecek önlemleri genel olarak aldığı ancak güvenli yazılım geliştirme ve sunucu/ağ yapılandırmalarının düzenli sıkılaştırmaları konularında eksiklerinin olduğu görülmektedir. Uygulamalarda hata mesajlarının yönetilmemesi, çalışmayan sayfa ve fonksiyonların canlı ortamda erişilebilir olması, güncel olmayan yapıların kullanılması bu duruma örnek olarak gösterilecek başlıca bulgulardır.

Tavsiye Özeti:

Bulguların çoğunluğu uygulama sıkılaştırma kök nedenine sahip olduğu düşünüldüğünde, Kurum bünyesinde güvenli yazılım geliştirme yaşam döngüsünün uygulanması, Kurumun verdiği hizmetlerin akışına göre uygulamaların gözden geçirilmesi bulguların büyük kısmının kapatılmasını sağlayacaktır. Sunucu ve servis sıkılaştırmaları ile güvenlik çözümlerinin bir arada kullanılması sayesinde Kurumun siber güvenlik seviyesinin artması ve olası bir siber olaya karşı hazır olması sağlanabilir.

Mobil Uygulama Sızma Testi Bulguları

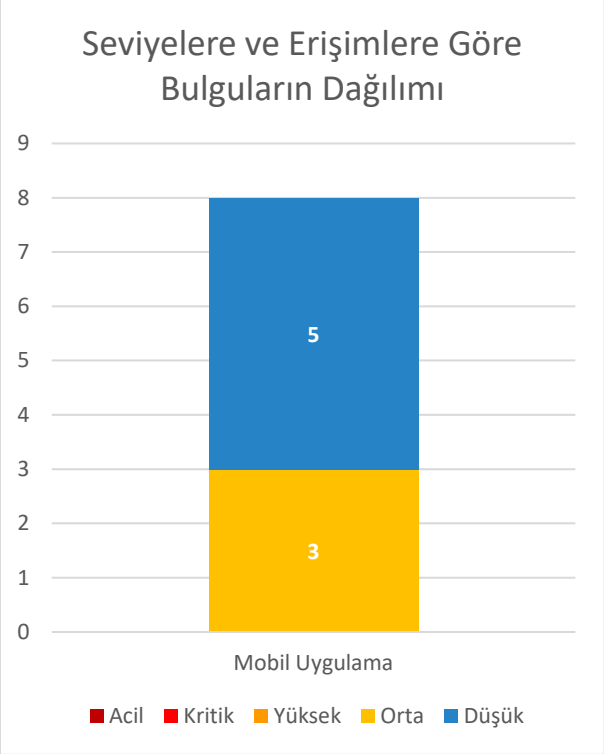
Seviye	Bulgu Adı	Etkilenen Sistem Sayısı
ORTA	İnternetten Erişilebilir Hassas Servisler	1
ORTA	Erişim Kontrolünün Olmaması	1
ORTA	Güncel Olmayan JavaScript Kütüphanesi Kullanımı	1
DÜŞÜK	Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması	1
DÜŞÜK	Hassas Bilgilerin Erişilebilir Olması	1
DÜŞÜK	HTTP Başlık Bilgisi Eksiklikleri	1
DÜŞÜK	Basic Authentication Kullanımı	1
DÜŞÜK	Uygulamada Güvensiz Veri Depolanması	1

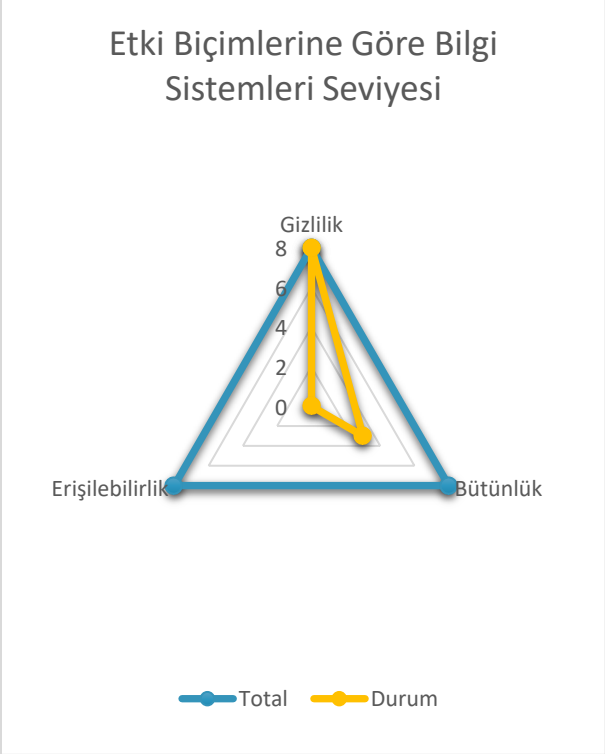
Bulgu Seviyeleri

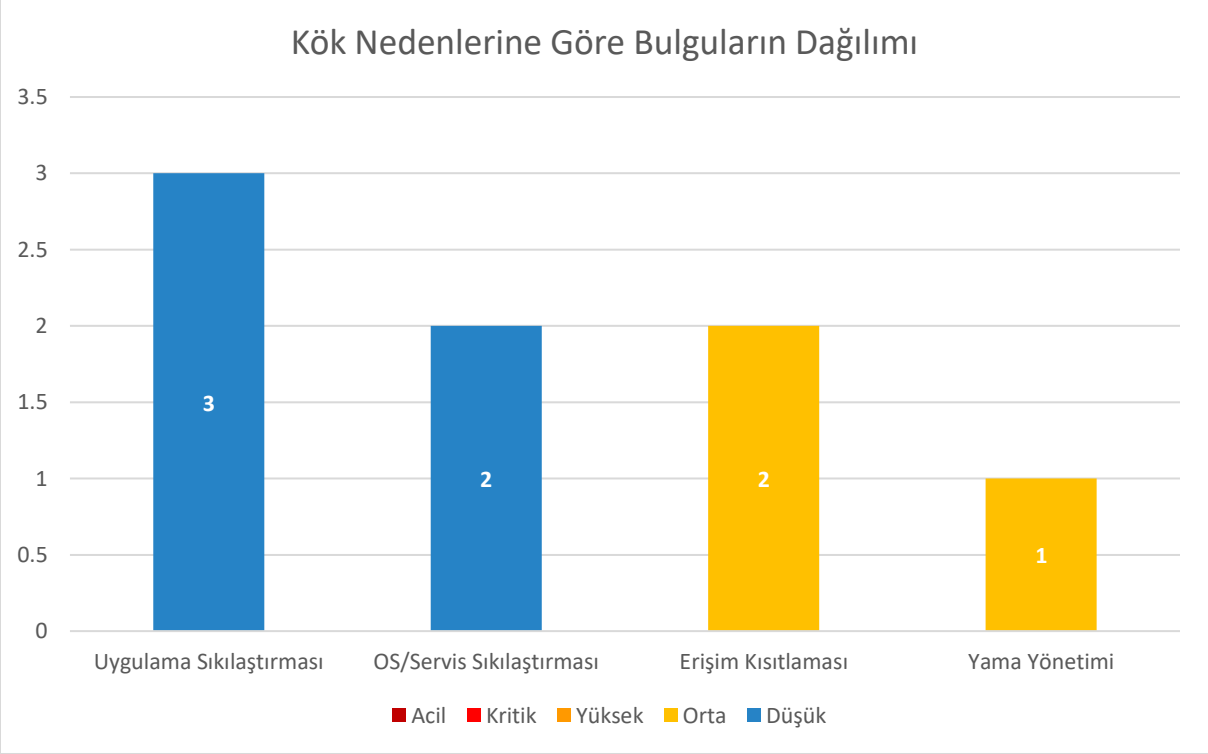
Seviye	Açıklama
ACİL	Saldırganların tam yetki ile uzaktan komut çalıştırmaya, servis dışı bırakma saldırıları gerçekleştirmeye veya kritik verilerin sızdırılması ile sonuçlanabilecek zafiyetlerdir.
KRİTİK	Düşük yetki ile komut çalıştırma, servis aksatma ve siber saldırganların daha büyük saldırıları yapmasına olanak tanıyan zafiyetlerdir.
YÜKSEK	Hedef sistem üzerinde diğer zafiyetlerde kullanılabilecek bilgileri açığa çıkaran, tetiklenmesi durumunda kaynak kullanımını arttırabilecek zafiyetlerdir.
ORTA	Tek başına zafiyet olarak değerlendirilmeyen fakat diğer zafiyetler ile kullanıldığında önemli olabilecek zafiyetlerdir.
DÜŞÜK	Bilgi seviyesinde önerilerdir. Sektör ile ilgili en iyi yapılandırmalar göz önüne alınarak belirtilen sistem sıkılaştırmalarıdır.

GİZLİ

Bulgu Grafikleri







Kök Nedenler

Kök Neden	Açıklama
Yama Yönetimi	Hedef sistemde eksik olan güvenlik yaması veya kurumun yama yönetim süreçlerinden kaynaklanan bulgular
Erişim Kısıtlaması	Test edilen kullanıcı profili ile erişilmesinin sakıncalı olduğu ve atak vektörü olarak kullanabilecek kaynakların tespiti ile ilişkili bulgular
Uygulama Sıkılaştırması	Uygulamaların üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular
OS/Servis Sıkılaştırması	İşletim sistemi veya servislerin üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular
Veritabanı Sıkılaştırması	Veritabanı üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular
Kullanıcı Yönetimi	Uygulamalar/servisler üzerinde kullanıcı yönetiminden kaynaklanan, kullanıcı adı/parolaların veya kullanıcı oturumunu etkileyebilecek bulgular
DNS Yapılandırması	DNS kayıtlarından veya DNS sunucu/servis mimarisi eksikliklerinden kaynaklanan bulgular
E-Posta Yapılandırması	E-Posta sunucu/servis mimarisi ve yapılandırma eksikliklerinden kaynaklanan bulgular
Ağ ve Sistem Mimarisi	İletişim altyapısı ve aktif cihazlar ile sistem mimarisi yapılandırma eksikliklerinden kaynaklanan bulgular
Girdi Kontrolü	Uygulamanın girdi aldığı alanlarda gerekli kontrollerin ve kısıtlamaların uygulanmamasından kaynaklanan bulgular

GİZLİ

Test Kapsamı

Testi Gerçekleştiren Firma RSU Bilişim ve Danışmanlık Hizmetleri A.Ş.		**Test Kapsamı Veri Sahibi Firma** Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti.
Testi Gerçekleştiren Personel Özge Gökmen		**Sorumlu Personel** Selim Tural
Raporu Hazırlayan Özge Gökmen	**Raporu Kontrol Eden** Kaan İlter	**Raporu Yayınlayan** Yıldız Balatürk Erkan
Test Başlangıç Tarihi 16.08.2024		**Raporlama Tarihi** 23.08.2024
Test Kapsamı Mobil Uygulama Sızma Testi - Inflight Android Uygulaması (v1.5.19)		**Test Profili** Erişim: İnternet Profil: Anonim, Standart Kullanıcı
Testte Kullanılan Kaynaklar İnternet: - 185.124.86.25/29		**Test Hesapları** Test Kullanıcıları: - Uygulama Kullanıcısı:4444

Uyarı

Rapor içeriği gizli olup iki tarafın yazılı mutabakatı olmadan üçüncü taraflara basılı olarak ya da elektronik ortamda transfer edilemez veya paylaşılamaz.

Rapor, tarama süresi içinde varlığı bilinen veya tarafımızdan tespit edilen güvenlik açıklıklarını içerecektir. Tarama işlemi bittikten sonra rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı RSU sorumlu tutulamaz.

Rapor içinde yer alan çözüm önerilerine konu hakkında fikir verme amaçlı yer verilmiştir. Çözüm önerilerinin uygulanması sebebi ile çıkabilecek problemlerden RSU sorumlu tutulamaz. Önerilerde sunulan değişikliklerden gerçekleştirilmeden önce konu hakkında uzman kişilerden destek alınması tavsiye edilir.

Romsis tarafından sağlanılan mobil uygulama test amaçlı HTTP protokolü üzerinden haberleştiği ve canlı ortamda HTTPS kullanılmasından kaynaklı, HTTP protokolü kullanılması ile ilgili bulgu yazılmayacağı konusunda mütabık kalınarak testler gerçekleştirilmiştir.

Sızma Testi Metodolojisi

Gerçekleştirilen sızma testi, OWASP (Açık Web Uygulaması Güvenlik Projesi) ve NIST (Ulusal Standartlar ve Teknoloji Enstitüsü) tarafından sağlanan yönergelerle uyumlu metodoloji çerçevesinde yürütülmüştür.

1. **Hazırlık Aşaması:**
    a. Sızma testinin kapsamının ve hedeflerinin belirlemesi.
    b. İlgili paydaşlardan yazılı yetkilerin alınması.
    c. Hedef sistemler ve uygulamalar hakkında ilgili bilgilerin toplanması.
    d. Uygulanabilir yasal veya düzenleyici gerekliliklerin belirlenmesi.
2. **İstihbarat Toplama:**
    a. Hedefle ilgili erişilebilir bilgilerin elde edilmesi.
    b. Ağ altyapısı, uygulamalar ve hizmetler hakkında bilgi toplanması için araçlar ve teknikler kullanılması.
    c. Potansiyel zafiyetlerin, güvenlik açıklarının ve saldırı vektörlerinin belirlenmesi.
3. **Tehdit Modelleme:**
    a. Hedef sistemlerin mimari yönlerinin analiz edilmesi ve potansiyel tehditlerin belirlenmesi.
    b. Potansiyel etkilerine ve olasılıklarına göre önceliklendirilen tehditlerin belirlenmesi.
    c. Saldırganlar için saldırı yüzeyinin ve potansiyel giriş noktalarının belirlenmesi.
4. **Zafiyet Analizi:**
    a. Otomatik araçlar ve manuel teknikler kullanılarak kapsamlı bir zafiyet değerlendirmesi yapılması.
    b. Hedef sistemlerde ve uygulamalarda tespit edilen zafiyetlerin belirlenmesi ve doğrulanması.
    c. Seviyeleri, potansiyel etkileri ve düzeltme adımlarını içeren kanıtların oluşturulması.
5. **İstismar:**
    a. Tespit edilen zafiyetlerin istismar edilerek yetkisiz erişim elde edilmesi veya hedef sistemler ile etkileşim girişiminde bulunulması.
    b. Etik hackleme teknikleri kullanılarak tespit edilen zafiyetlerin varlığının ve etkisinin doğrulanması.
    c. Başarılı istismar girişimlerinin adımlarının ve sonuçlarının belgelenmesi.
6. **İstismar Sonrası:**
    a. Elde edilen sistemlerde daha fazla bilgi toplama ve erişimi genişletmek için derinlemesine bir araştırma yapılması.
    b. Yetkileri yükseltme, süreklilik sağlama veya diğer sistemlere geçiş yapma fırsatların aranması.
    c. İstismar sonrası aşamasında gerçekleştirilen faaliyetlerin ve hedef ortamındaki potansiyel risklerin belgelemesi.
7. **Raporlama:**
    a. Belirlenen zafiyetleri, etkilerini ve düzeltme önerilerini içeren kapsamlı bir rapor derlenmesi.
    b. Potansiyel etkilerine göre belirlenen bulguların seviyelendirilmesi.
    c. Yönetici özeti, detaylı teknik bilgiler ve genel güvenlik durumunu iyileştirmek için öneriler sağlanması.
8. **Düzeltme ve Doğrulama:**

a. Belirlenen zafiyetleri ele almak için paydaşlarla iş birliği yaparak bir eylem planı oluşturulması.
b. Önerilen düzeltme adımlarının doğru bir şekilde uygulandığının doğrulanması.
c. Düzeltme çabalarının etkinliğini doğrulamak için yeniden test veya takip değerlendirmesin yapılması.

Mobil Uygulama Sızma Testi Kontrol Listesi

1. Veri Depolama ve İletimi: Veri depolama ve iletiminin güvenliği, şifreleme, güvenli depolama mekanizmaları ve güvenli ağ iletişimi konularının gözden geçirilmesi.
2. Kimlik Doğrulama ve Yetkilendirme: Mobil uygulamadaki kimlik doğrulama ve yetkilendirme mekanizmalarının güvenliğinin değerlendirilmesi.
3. Kod İncelemesi: Mobil uygulamanın kaynak kodlarının güvenlik açıkları açısından kapsamlı bir şekilde gözden geçirilmesi.
4. Güvenli API: Mobil uygulama tarafından kullanılan API'ların güvenliği, kimlik doğrulama, erişim kontrolleri ve veri doğrulama konularında değerlendirme.
5. Platform Güvenliği: Mobil işletim sistemi platformunda uygulanan güvenlik yapılandırmalarının ve sıkılaştırma önlemlerinin değerlendirilmesi.
6. Binary Analizi: Uygulamanın binary kodunun incelenmesi, potansiyel güvenlik zafiyetlerinin ve açıklarının belirlenmesi.
7. Anti-Manipülasyon ve Tersine Mühendislik: Anti-manipülasyon önlemlerinin etkinliğinin ve tersine mühendislik girişimlerine karşı direncin test edilmesi.
8. Güvenli Veri Silme: Uygulama kaldırıldığında cihazdan hassas verilerin uygun bir şekilde silindiğinin doğrulanması.

Kullanılan Araçlar

- Nessus	- Burp Suite	- Zaproxy	- Sqlmap	- Masscan	- Ffuf
- Nmap	- Metasploit	- Wpscan	- Nikto	- SSLyze	- Websploit
- Wireshark	- Commix	- Gobuster	- Netscan	- DirBuster	- nuclei

MOBİL UYGULAMA SIZMA TESTİ BULGULARI

1. Acil Seviye Mobil Uygulama Sızma Testi Bulguları

Acil seviye bulgu tespit edilmemiştir.

2. Kritik Seviye Mobil Uygulama Sızma Testi Bulguları

Kritik seviye bulgu tespit edilmemiştir.

3. Yüksek Seviye Mobil Uygulama Sızma Testi Bulguları

Yüksek seviye bulgu tespit edilmemiştir.

4. Orta Seviye Mobil Uygulama Sızma Testi Bulguları

4.1. İnternetten Erişilebilir Hassas Servisler		RS.240823.RAJ.401
Seviye: Orta		
Etkilenen Sistem: bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
	Etki Biçimi:	Gizliliğin Bozulması
	Kök Neden:	Erişim Kısıtlaması

Açıklama:

Sunucular üzerinde kullanılan servislerin gerekli olmadıkça internet üzerinden kontrolsüz erişime açık olmaması gerekmektedir. FTP, SSH, MySQL gibi çeşitli servisler kimlik doğrulama metotları ile korunuyor olsa dahi ileride ortaya çıkabilecek bir açıklık ile yetkisiz erişime neden olabilir.

Yapılan incelemeler sonucunda internetten kontrolsüz erişime açık FTP servisi tespit edilmiştir. Test amaçlı "anonymous" giriş ve kaba kuvvet saldırıları düzenlenmiştir.

Çözüm Önerisi:

HTTP servisleri dışındaki servislerin internetten kontrolsüz erişime kapatılması tavsiye edilmektedir. Bu servislerin internet üzerinden erişim vermesi zorunlu ise IP kısıtlaması ya da VPN teknolojileri ile erişimin sınırlandırılması tavsiye edilmektedir.

Kaynak:

How to restrict MySQL port access
https://www.a2hosting.com/kb/developer-corner/mysql/restricting-mysql-port-access
how can i disable remote access of mysql?
https://www.digitalocean.com/community/questions/how-can-i-disable-remote-access-of-mysql
How to Restrict FTP Access by IP (via IIS)
https://support.managed.com/kb/a2208/how-to-restrict-ftp-access-by-ip-via-iis.aspx

Ekran Görüntüsü:

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- --open bob.romsis.com.tr
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-16 08:43 EDT
Nmap scan report for bob.romsis.com.tr (93.89.224.110)
Host is up (0.035s latency).
rDNS record for 93.89.224.110: 93-89-224-110.fbs.com.tr
Not shown: 65533 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE
21/tcp open  ftp
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 277.34 seconds
```

GİZLİ

```
[*]93.89.224.110:21    - 93.89.224.110:21 - Starting FTP login sweep
[!]93.89.224.110:21    - No active DB -- Credential data will not be saved!
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:anonymous (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:rootpasswd (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:12hrs37 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:b1uRR3 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:admin (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:localadmin (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:1234 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:apc (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:nas (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:wago (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:wago (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:user (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:guest (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:ftp (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:password (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:avery (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:123456 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:none (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:admin12345 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:dpstelecom (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:instrument (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:password (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:password (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:default (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:default (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:1234 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:Janitza (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:supervisor (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:pass1 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:avery (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:eMerge (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:12345 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:beijer (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:admin (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:1234 (Incorrect: )
[-]93.89.224.110:21    - 93.89.224.110:21 - LOGIN FAILED: admin:1111 (Incorrect: )
```

4.2. Erişim Kontrolünün Olmaması			RS.240823.RAJ.402
Seviye:	**Orta**		
Etkilenen Sistem:	bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması Bütünlüğün Bozulması
		Kök Neden:	Erişim Kısıtlaması

Açıklama:

Erişim kontrolü/yetkilendirme, yapılan işlemleri kimin gerçekleştirebileceğine ve talep edilen kaynaklara kimin erişebileceğine ilişkin kısıtlamaların uygulanmasıdır. Uygulamalarda erişim kontrolleri kimlik doğrulama (authentication) ve oturum yönetimi (session management) üzerinden sağlanmaktadır. Kullanıcı açısından bakıldığında, erişim kontrolleri aşağıdaki 3 kategoriye ayrılabilir:

• Dikey erişim kontrolleri (Vertical access controls)
• Yatay erişim kontrolleri (Horizontal access controls)
• Kaynağa bağlı erişim kontrolleri (Context-dependent access control)

Eksik yapılan kontroller sonucunda anonim veya yetkisiz kullanıcılar tarafından kritik kaynaklara erişim ve manipülasyon işlemleri gerçekleştirilebilir.

Yapılan incelemeler sonucunda uygulamaya giriş yaparken şifre ile girildiği fakat sunucu tarafında yetkilendirme yapılmamasından kaynaklı isteklerin kullanılmaya devam edildiği tespit edilmiştir.

Etkilenen uç nokta bilgileri:

- http://bob.romsis.com.tr/mobileflight/aktifucuslar
- http://bob.romsis.com.tr/MobileFlight/GetFlight/?UcusNo=27604
- http://bob.romsis.com.tr/MobileFlight/SetFlight

Çözüm Önerisi:

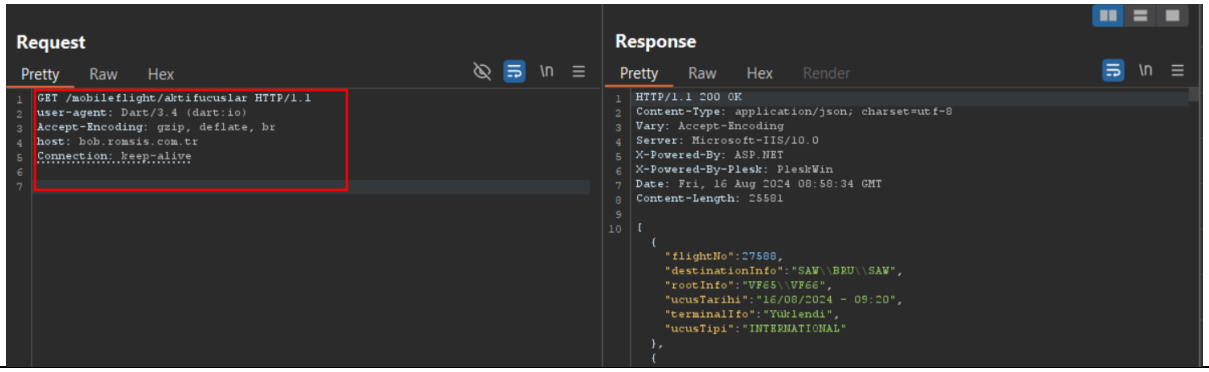
- Kullanıcı rollerine yapılabilecek ve yapılamayacak işlemler için uygun erişim kontrolleri tanımlanmalıdır.
- Bir kaynağın herkes tarafından erişilebilir olması amaçlanmadıkça, varsayılan olarak kaynağa erişim reddedilmelidir.
- Tasarlandığı gibi çalıştığından emin olmak için erişim kontrolleri baştan sona test edilmelidir.

Kaynak:

Access control vulnerabilities and privilege escalation
https://portswigger.net/web-security/access-control
A5:2017-Broken Access Control
https://owasp.org/www-project-top-ten/2017/A5_2017-Broken_Access_Control
Broken Access Control
https://hdivsecurity.com/owasp-broken-access-control

GİZLİ

Ekran Görüntüsü:



Request

Pretty Raw Hex

```
GET /mobileflight/aktifucuslar HTTP/1.1
user-agent: Dart/3.4 (dart:io)
Accept-Encoding: gzip, deflate, br
host: bob.romsis.com.tr
Connection: keep-alive
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
X-Powered-By-Plesk: PleskWin
Date: Fri, 16 Aug 2024 08:58:34 GMT
Content-Length: 25581

[
  {
    "flightNo":27588,
    "destinationInfo":"SAW\\BRU\\SAW",
    "rootInfo":"VF65\\VF66",
    "ucusTarihi":"16/08/2024 - 09:20",
    "terminalIfo":"Yüklendi",
    "ucusTipi":"INTERNATIONAL"
  },
  {
```

4.3. Güncel Olmayan JavaScript Kütüphanesi Kullanımı		RS.240823.RAJ.403
Seviye: Orta		
Etkilenen Sistem: bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
	Etki Biçimi:	Gizliliğin Bozulması Bütünlüğün Bozulması
	Kök Neden:	Yama Yönetimi

Açıklama:

Güvenlik zafiyeti oluşturan JavaScript kütüphaneleri kullanılarak uygulama içerisine zararlı kodlar enjekte edilebilmekte ve uygulama yaşam döngüsüne bağlı olarak kullanıcı oturumları çalınabilmektedir. Bu nedenle bilinen zafiyetleri barındıran ve güncel olmayan JavaScript kütüphanelerinin kullanımından kaçınılması gerekir.

Yapılan incelemelerde uygulama içerisinde kullanılan, aşağıda belirtilmiş JavaScript kütüphanelerinin güncel olmadığı ve bilinen zafiyetlere sahip oldukları gözlenmiştir.

jQuery3.2.1

- http://bob.romsis.com.tr/login/vendor/jquery/jquery-3.2.1.min.js
- CVE-2020-11022,CVE-2020-11023,CVE-2019-11358

bootstrap 4.0.0

- http://bob.romsis.com.tr/login/vendor/bootstrap/css/bootstrap.min.css
- CVE-2024-6485, CVE-2024-6484

moment.js 2.13.0

- http://bob.romsis.com.tr/login/vendor/daterangepicker/moment.min.js
- CVE-2022-24785, CVE-2017-18214

select2 4.0.3

- http://bob.romsis.com.tr/login/vendor/select2/select2.min.js
- CVE-2016-10744

Çözüm Önerisi:

Kullanılan JavaScript kütüphanelerinin güncel kararlı sürümlere yükseltilmesi tavsiye edilmektedir.

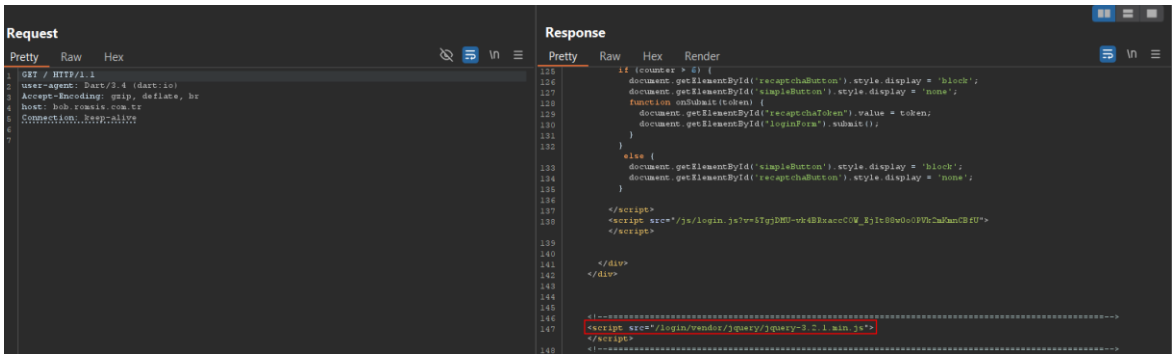
Bulguya tabii kütüphanelere ilişkin güncel sürümler aşağıdaki gibidir:
jQuery:3.7.1
bootstrap: 5.3
moment.js: 2.30.1
select2:4.1.0

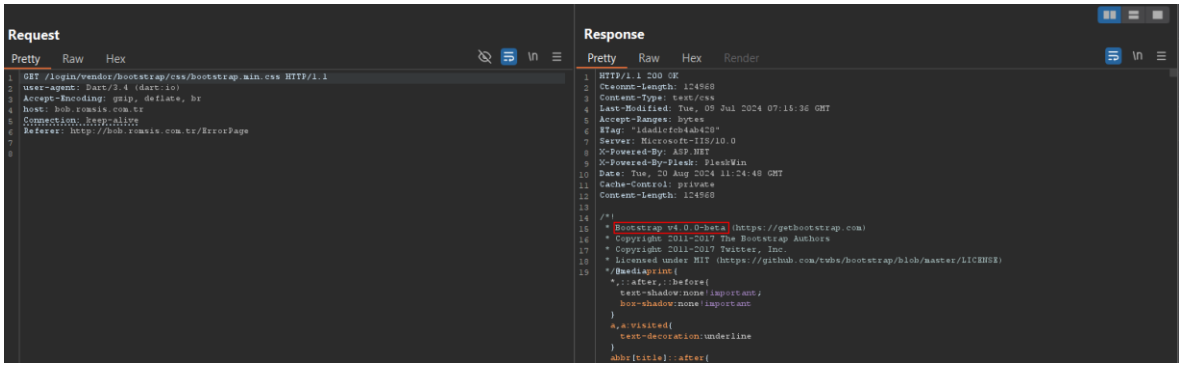
Kaynak:

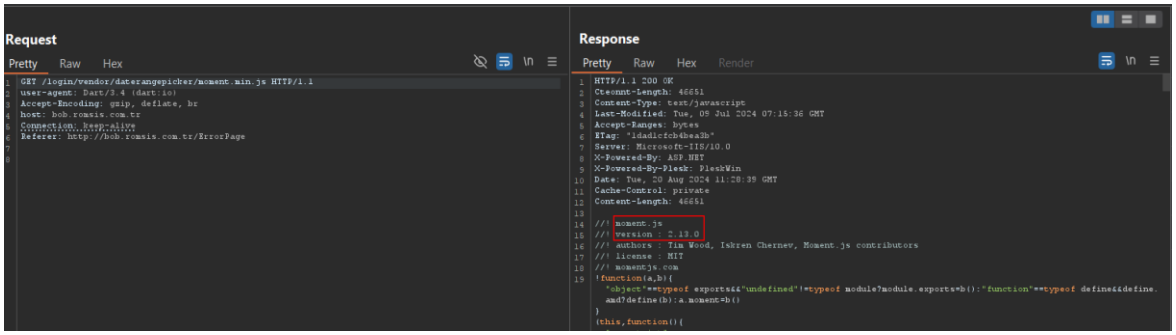
Over a Third of Websites Use Outdated and Vulnerable JavaScript Libraries
https://www.bleepingcomputer.com/news/security/over-a-third-of-websites-use-outdated-and-vulnerable-javascript-libraries/
https://nvd.nist.gov/vuln/detail/CVE-2020-11022
https://nvd.nist.gov/vuln/detail/CVE-2020-11023
https://nvd.nist.gov/vuln/detail/CVE-2019-11358
https://security.snyk.io/vuln/SNYK-JS-BOOTSTRAP-7444617

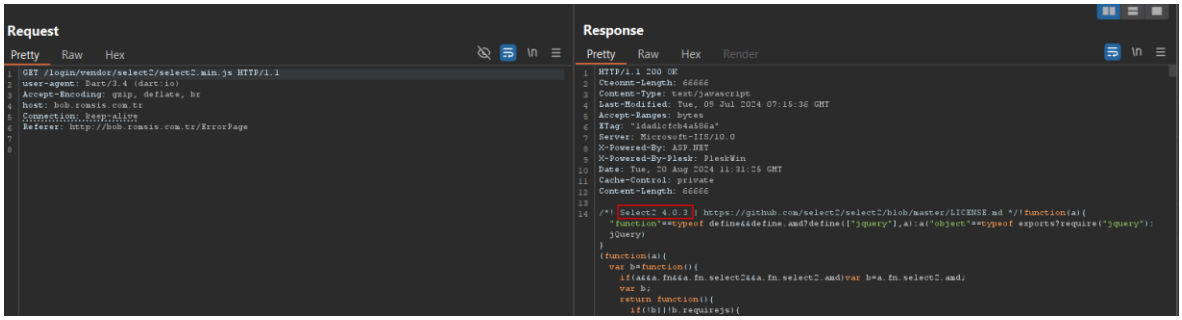
https://security.snyk.io/vuln/SNYK-JS-BOOTSTRAP-7444593
https://nvd.nist.gov/vuln/detail/CVE-2022-24785
https://nvd.nist.gov/vuln/detail/CVE-2017-18214
https://nvd.nist.gov/vuln/detail/CVE-2016-10744

Ekran Görüntüsü:









5. Düşük Seviye Mobil Uygulama Sızma Testi Bulguları

5.1. Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması			RS.240823.RAJ.501
Seviye:	**Düşük**		
Etkilenen Sistem:	bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	OS/Servis Sıkılaştırması

Açıklama:

Web sunucu ve uygulamalar varsayılan olarak HTTP başlıklarında ve uygulama içerisinde kullanılan teknoloji ve kütüphaneler ile sürüm bilgilerini gönderilen cevaplar içerisine eklemektedir. Saldırganlar hedef sistem hakkında bilgi toplamak ve altyapı analizi için bu tür bilgileri kullanarak neler yapılabileceğinin çıktısını üretirler.

Yapılan incelemerde, etkilenen sistemlerde belirtilen web sunucular ve üzerlerinde çalışan teknolojiler ile ilgili versiyon bilgisinin açığa çıkarıldığı tespit edilmiştir.

Başlık bilgileri ile açığa çıkan bilgiler:

- Server: Microsoft-IIS/10.0
- X-Powered-By: ASP.NET
- X-Powered-By-Plesk: PleskWin

Çözüm Önerisi:

Web sunucu ve uygulamalar için X-Powered-By, Server gibi başlıklar başta olmak üzere, sistem hakkında bilgi verebilecek başlık ve çıktılar konfigürasyonlar üzerinden devre dışı bırakılmalıdır.

Kaynak:

Fingerprint Web Server
https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server
Petefreitag - Apache security
http://www.petefreitag.com/item/505.cfm
MSDN - Error Handling in ASP.NET Pages and Applications
http://msdn.microsoft.com/en-us/library/w16865z6.aspx
Web Application Fingerprinting
https://capec.mitre.org/data/definitions/170.html

GİZLİ

Ekran Görüntüsü:

Request

Pretty Raw Hex

```
GET /mobileflight/aktifucuslar HTTP/1.1
user-agent: Dart/3.4 (dart:io)
Accept-Encoding: gzip, deflate, br
host: bob.romsis.com.tr
Connection: keep-alive
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
X-Powered-By-Plesk: PleskWin
Date: Fri, 16 Aug 2024 08:58:34 GMT
Content-Length: 25581

[
  {
    "flightNo":27588,
    "destinationInfo":"SAW\\BRU\\SAW",
    "rootInfo":"VF65\\VF66",
    "ucusTarihi":"16/08/2024 - 09:20",
    "terminalIfo":"Yüklendi",
    "ucusTipi":"INTERNATIONAL"
  },
  {
    "flightNo":27589,
    "destinationInfo":"SAW\\BGW\\SAW",
    "rootInfo":"VF133\\VF132",
    "ucusTarihi":"16/08/2024 - 13:15",
    "terminalIfo":"Yüklendi",
    "ucusTipi":"INTERNATIONAL"
  },
  {
    "flightNo":27590,
    "destinationInfo":"SAW\\AMS\\SAW",
    "rootInfo":"VF3\\VF4",
    "ucusTarihi":"16/08/2024 - 13:50",
    "terminalIfo":"Beklemede",
    "ucusTipi":"INTERNATIONAL"
  },
```

5.2. Hassas Bilgilerin Erişilebilir Olması			RS.240823.RAJ.502
Seviye:	**Düşük**		
Etkilenen Sistem:	bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

Bir uygulama ya da sunucu üzerinde kullanıcı, sunucu, uygulama hakkında hassas ya da hassas olabilecek verilerin internet üzerinden kontrolsüz erişime kapalı olması beklenir. Bu veriler kötü niyetli bir kullanıcı/saldırganın eline geçtiğinde sisteme zarar vermek, sistemi ele geçirmek ya da saldırı için yol haritası oluşturmak amacıyla kullanılabilir.

Yapılan incelemeler sonucunda uygulamanın Windows sunucuda koştuğu ve sunucu iç dizinlerinin Windows ~ işareti ile tahmine açık olduğu tespit edilmiştir. Tespit sırasında OPTIONS metodu kullanılmış ve /~1/.rem dizini tespit edilmiştir.

Çözüm Önerisi:

Tilde karakterini kullanan tüm web isteklerinin kabul edilmemesini ve HKLM\SYSTEM\CurrentControlSet\Control\FileSystem öğesine NtfsDisable8dot3NameCreation adlı bir kayıt defteri anahtarı eklenmesi tavsiye edilmektedir. Sunucudaki tüm 8.3 ad kurallarını azaltmak için anahtarın değerini 1 olarak ayarlanması önerilmektedir.

Kaynak:

https://www.acunetix.com/vulnerabilities/web/microsoft-iis-tilde-directory-enumeration/
https://www.tenable.com/plugins/was/112442

Ekran Görüntüsü:

```
└─$ java -jar iis_shortname_scanner.jarhttp://bob.romsis.com.tr/
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Do you want to use proxy [Y=Yes, Anything Else=No]?
# IIS Short Name (8.3) Scanner version 2023.4 - scan initiated 2024/08/16 09:16:23
Target: http://bob.romsis.com.tr/
|_ Result: Vulnerable!
|_ Used HTTP method: OPTIONS
|_ Suffix (magic part): /~1/.rem
|_ Extra information:
  |_ Number of sent requests: 27
```

5.3. HTTP Başlık Bilgisi Eksiklikleri			RS.240823.RAJ.503
Seviye:	**Düşük**		
Etkilenen Sistem:	bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması Bütünlüğün Bozulması
		Kök Neden:	OS/Servis Sıkılaştırması

Açıklama:

HTTP başlık bilgisi eksiklikleri web uygulaması güvenliği açısından önemli bir rol oynamaktadır. Bu başlık bilgilerinin kullanılması XSS, Clickjacking ve HSTS gibi yapılandırma eksikliklerine karşı son kullanıcıları daha güvenli hale getirecektir.

Yapılan incelemeler sonucunda, etkilenen sistemlerde belirtilen web sunucuların güvenlik ile ilişkili HTTP başlıklarında eksikliklerin olduğu tespit edilmiştir.

- Strict-Transport-Security

bob.romsis.com.tr

- X-Frame-Options

bob.romsis.com.tr

- X-Content-Type-Options

bob.romsis.com.tr

- Content-Security-Policy

bob.romsis.com.tr

- Referrer-Policy

bob.romsis.com.tr

Çözüm Önerisi:

Aşağıda belirtilen başlık bilgilerinin tüm web sayfaları cevaplarında görüntülenecek şekilde yapılandırılması gerekmektedir. Başlık bilgilerinin kullanılması sonucunda clickjacking saldırı koruması, tarayıcı XSS koruması, içerik koruması, zorunlu SSL kullanımı ve önbellek kontrolü gibi yapılandırma ayarları aktif hale gelmiş olur.

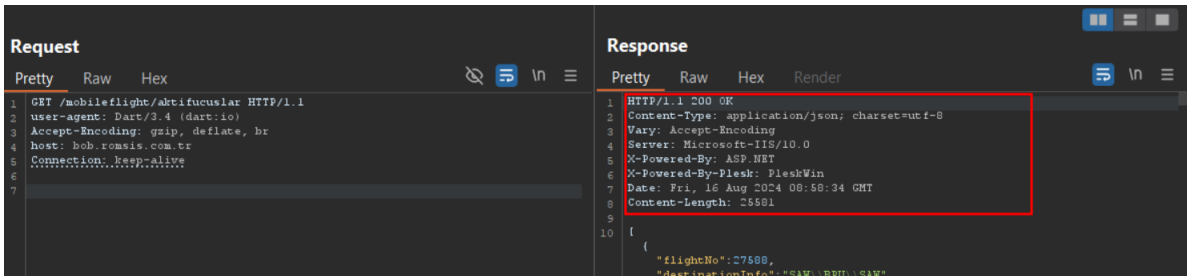
Strict-Transport-Security: max-age=16070400; includeSubDomains
X-Frame-Options: sameorigin
X-Content-Type-Options:nosniff
Cache-Control: no-cache, no-store, must-revalidate
Content-Security-Policy: KONTROL_ALANI değerler
Referrer-Policy: no-referrer

Kaynak:

Clickjacking Defense Cheat Sheet
https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet
List of useful HTTP headers
https://www.owasp.org/index.php/List_of_useful_HTTP_headers
HTTP Strict Transport Security
https://www.owasp.org/index.php/HTTP_Strict_Transport_Security
Best nginx configuration for improved security
https://gist.github.com/plentz/6737338
Referrer-Policy Not Implemented

https://www.netsparker.com/web-vulnerability-scanner/vulnerability-security-checks-index/referrer-policy-not-implemented/
CSP -Content Security Policy
https://www.netsparker.com.tr/blog/web-guvenligi/CSP-Content-Security-Policy/
Using the Same-Site Cookie Attribute to Prevent CSRF Attacks
https://www.netsparker.com/blog/web-security/same-site-cookie-attribute-prevent-cross-site-request-forgery/

Ekran Görüntüsü:



5.4. Basic Authentication Kullanımı			RS.240823.RAJ.504
Seviye:	**Düşük**		
Etkilenen Sistem:	bob.romsis.com.tr:80	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

HTTP Basic Authentication (Temel kimlik doğrulaması), istemcinin istekte bulunurken kullanıcı adı ve parola sağlaması için kullanılan bir yöntemdir. Sunucu tarafında belirli bir dosya veya tüm çalışma alanı için kurulabilen bu doğrulama yönteminde istemcinin doğru giriş bilgilerini girmesi gerekmektedir. Basic authentication ile kullanıcı kimlik bilgileri base64 encoding yöntemi ile encode edilerek olarak HTTP istek başlıklarında gönderilir. Saldırganlar tarafından gönderilen bu istek rahatlıkla decode edilebilir doğrulama esnasında sunucuya iletilen istekler saldırgan tarafından elde edilebilir. Ayrıca kimlik bilgileri HTTP başlığında olduğundan ağ ve güvenlik cihazları tarafından loglanması ve browserda cachlenmesi gibi durumlara karşı risk taşımaktadır. Basic Authentication'ın bruteforce saldırılarına karşı savunmasızdır. Aynı zamanda bu kimlik doğrulama yöntemi oturum kapatma desteği sunmadığı için bir kere erişim sağlanan sistemde uzun süre oturum açık kalmaktadır.

Aynı zamanda bu oturum açma yönteminde parola politikası uygulamak ve Düzenli parola değiştirmek mümkün olmadığı için güvenlik risklerini de beraberinde getirmektedir.

Yapılan incelemeler esnasında; mobil uygulama domaini için bilgi toplama adımında yapılan dizin taraması "/job" dizinini tespit etmiş ve bu dizin kontrol edildiğinde "Basic Authentication" kullanıldığı gözlemlenmiştir.

Etkilenen uç nokta bilgisi:

- http://bob.romsis.com.tr/job

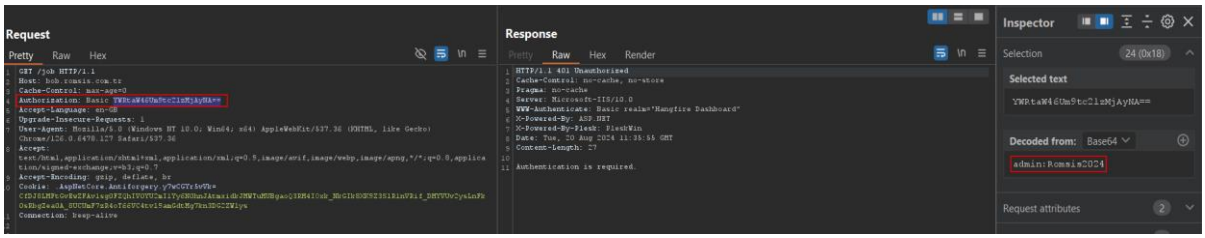
Çözüm Önerisi:

Uygulamaların kullanıcı doğrulama aşamalarında iyi güvenlik pratiği olarak, kullanıcı kimlik bilgileri POST isteği ile istek gövdesinde iletilmesi önerilmektedir. Bu yapı, yetkilendirme yönetiminde kullanılacağı durumlarda ise JWT (JSON Web Token) yapılarının kullanılması önerilmektedir.

Kaynak:

Is BASIC-Auth secure if done over HTTPS
https://security.stackexchange.com/a/990
Basic authentication over HTTP
https://www.acunetix.com/vulnerabilities/web/basic-authentication-over-http/

Ekran Görüntüsü:



5.5. Uygulamada Güvensiz Veri Depolanması			RS.240823.RAJ.505
Seviye:	**Düşük**		
Etkilenen Sistem:	AJet Inflight Mobil Uygulaması	**Erişim/Profil:**	İnternet/Anonim
		Etki Biçimi:	Gizliliğin Bozulması
		Kök Neden:	Uygulama Sıkılaştırması

Açıklama:

Mobil uygulamalar içerisinde bulunan ve cihazda saklanan dosyalar üzerinde hassas bilgi barındırılmamalıdır. Bu tarz hassas verilerin uygulamanın cihazda sakladığı dosyalarda açık bir şekilde korumasız olarak barındırılması saldırgan kişinin bu bilgiyi düzenleyeceği saldırılarda kullanmasına sebep olacaktır.

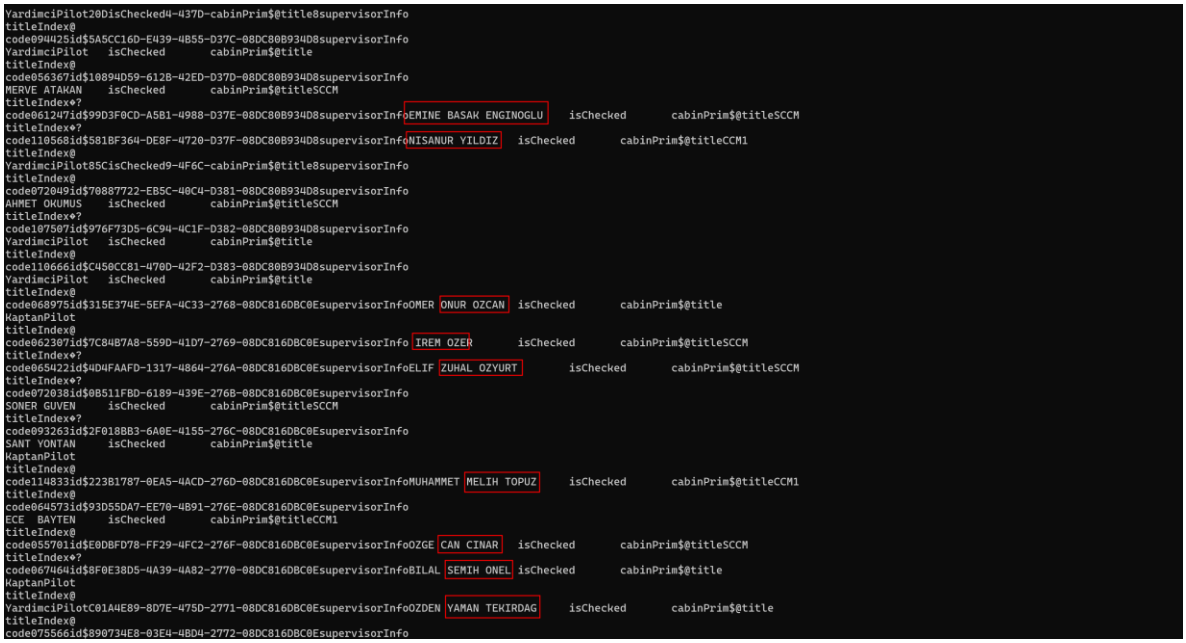
Yapılan incelemeler sonucunda /data/data/com.example.ajet_mobile/app_flutter/hivebox.hive dosyasında kabin görevlilerinin bilgilerinin yer aldığı gözlemlenmiştir.

Çözüm Önerisi:

Mobil uygulama üzerinde gerekmedikçe veri depolaması yapılmamalıdır. Veri depolaması yapılması gerektiğinde mümkünse bu verilerin şifreli bir şekilde saklanması önerilmektedir. Uygulama üzerinde kullanılan hassas verilerin dosya dizini içerisinde saklanacaksa şifrelenmesi ya da dizine yazılmadan şifreli olarak kullanılması önerilmektedir.

Hassas verilerin keystore altında bulunan uygulamaya özel alanda tutulması önerilmektedir.

Kaynak:

M2: Insecure Data Storage
https://owasp.org/www-project-mobile-top-10/2016-risks/m2-insecure-data-storage
Saving Data in SQL Databases
https://developer.android.com/training/basics/data-storage/databases.html

Ekran Görüntüsü: